03 03 Phase 3 Security Konzept

Phase 3: Security und Monitoring

Zeitraum: Nach Abschluss von Phase 2
Status: Vorbereitet / noch offen
Fokus: Monitoring, IDS/IPS, Incident Response und ISO 27001

Kernziele

- Zentrale Ueberwachung von Logs, Events und Netzwerkzustand aufbauen
- IDS/IPS-Mechanismen und Alerting einfuehren
- Incident-Response-Ablauf fachlich und organisatorisch absichern
- ISO-27001-relevante Kontrollen auf den erreichten Infrastrukturstand abbilden

Geplante Bausteine

- Zentraler Syslog- oder Monitoring-Stack
- IDS-/Alerting-Konzept fuer pfSense und Server
- Review der Backup- und Restore-Nachweise
- Auditvorbereitung mit Control-Mapping und Lueckenanalyse

Zusaetzliche Nachweise und sinnvolle Erweiterungen

Beispiel fuer hostbasiertes Alerting

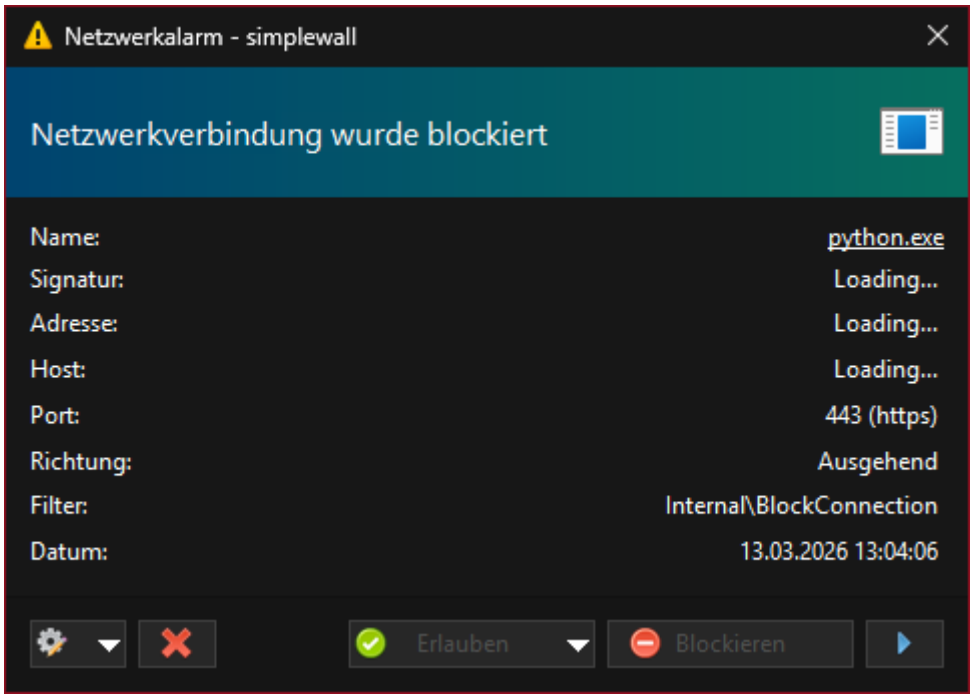

Figure 1: simplewall Warnung fuer ausgehende Python-HTTPS-Verbindung

Der Screenshot aus dem Praktikumsordner zeigt einen konkreten Netzwerkwarnfall auf Host-Ebene. Auch wenn Phase 3 noch nicht operativ umgesetzt ist, laesst sich daraus ein sinnvoller Baustein fuer die Security-Phase ableiten:

- ausgehende Verbindungen unbekannter Prozesse sichtbar machen
- Freigabe- und Blockierentscheidungen dokumentieren
- Host-Alerts mit Netzwerk- und Server-Logs korrelieren

Analyse- und Triage-Referenz

Die Wireshark-Filterreferenz eignet sich als operative Hilfe fuer die geplante Incident-Erkennung, insbesondere fuer DNS-, DHCP-, TLS- und VLAN-bezogene Untersuchungen.

Relevante Dokumente

- 03_03a_Incident_Response_Plan.md
- 03_03b_ISO27001_Checkliste.md
- 01_02_Analyse_Firewall_Hardening.md
- 04_02_Risiko_Register.md
- 04_03_Uebergabe_Protokoll.md

Einordnung

Phase 3 ist noch nicht operativ umgesetzt. Die noetigen Vorarbeiten, Risiken und Leitdokumente sind jedoch vorhanden, sodass die Security-Phase direkt aus dem dokumentierten Stand von Phase 2 gestartet werden kann.

Useful Wireshark Filters

©Cyber Threat Intelligence

- ip.addr == 10.0.0.1: Show all traffic with 10.0.0.1 as either source or destination.
- ip.addr == 10.0.0.0/24: Show all traffic to and from any address in 10.0.0.0/24.
- ip.src == 10.0.0.1 && ip.dst == 10.0.0.2: Show all traffic from 10.0.0.1 to 10.0.0.2.
- !(ip.addr == 10.0.0.1): Exclude all traffic to or from 10.0.0.1.
- icmp.type == 3: Show ICMP "destination unreachable" packets.
- tcp or udp: Show TCP or UDP traffic.
- tcp.port == 80: Show TCP traffic with port 80.
- tcp.srcport < 1000: Show TCP traffic with source port range.
- http or dns: Show all HTTP or DNS traffic.
- tcp.flags.syn == 1: Show TCP packets with SYN flag set.
- tcp.flags == 0x012: Show TCP packets with both SYN and ACK flags set.
- tcp.analysis.retransmission: Show all retransmitted TCP packets.
- http.request.method == "GET": Show TCP packets associated with HTTP GET.
- http.response.code == 404: Show packets associated with HTTP 404 response.
- http.host == "www.abc.com": Show HTTP traffic matching the Host header field.
- tls.handshake: Show only TLS handshake packets.
- tls.handshake.type == 1: Show client Hello packet during TLS handshake.
- dhcp and ip.addr == 10.0.0.0/24: Show DHCP traffic for 10.0.0.0/24 subnet.
- dhcp.hw.mac_addr == 00:11:22:33:44:55: Show DHCP packets for client MAC address.
- dns.resp.name == cnn.com: Show DNS responses with name field of "cnn.com".
- frame contains keyword: Show all packets that contain the word "keyword".
- frame.len > 1000: Show all packets with total length larger than 1000 bytes.
- eth.addr == 00:11:22:33:44:55: Show all traffic to or from the specified MAC address.
- eth[0x47:2] == 01:80: Match Ethernet frames with 2 bytes at offset 0x47 == 01:80.
- !(arp or icmp or stp): Filter out background traffic from ARP, ICMP, and STP.
- vlan.id == 100: Show packets with VLAN ID 100.

Figure 2: Wireshark Filter Referenz